

Contexte général : Mise en conformité PCI DSS de l'entreprise WebMarket

WebMarket est une entreprise française de taille moyenne spécialisée dans la vente en ligne de matériel électronique. Son activité repose principalement sur sa plateforme e-commerce, qui attire plusieurs milliers de clients chaque jour et génère environ 2 500 transactions quotidiennes. L'entreprise emploie une centaine de personnes, mais ne dispose ni d'un responsable de la sécurité des systèmes d'information, ni de politique formelle en matière de cybersécurité. Les aspects techniques et opérationnels sont gérés par trois développeurs chargés du site web et un administrateur système responsable de l'infrastructure.

Le site de WebMarket est hébergé sur un serveur virtuel appartenant à un prestataire cloud. La plateforme e-commerce s'appuie sur une base de données stockant les informations personnelles des clients, ainsi que certains éléments liés aux transactions. Même si les numéros de carte apparaissent tronqués dans les fiches clients, plusieurs exportations historiques contiennent encore des données sensibles en clair, laissées par d'anciens outils de reporting. Des sauvegardes de la base sont réalisées régulièrement, mais elles sont conservées sans chiffrement au sein de la salle informatique, dont l'accès physique n'est pas rigoureusement contrôlé.

Le processus de paiement repose sur une intégration directe avec l'API du prestataire PayNow. Pour chaque achat, le site recueille les informations complètes de la carte de paiement afin de les transmettre au prestataire pour autorisation. Il arrive fréquemment que des journaux applicatifs conservent des numéros de carte complets, en particulier lors des phases de développement ou de résolution d'incidents. L'ensemble du système d'information interne repose sur un réseau unique, sans segmentation particulière entre les postes utilisateurs, les serveurs internes et les systèmes potentiellement sensibles. Les règles du pare-feu principal sont nombreuses, peu documentées et parfois trop permissives. Certains équipements conservent encore leurs mots de passe d'origine, et les accès administratifs ne sont protégés que par une authentification simple, sans recours à une solution multifactorielle.

La société n'a mis en place aucun dispositif de détection d'intrusion, et la supervision des journaux est inexistante. Les vulnérabilités techniques ne sont suivies dans aucun processus formalisé : les mises à jour sont appliquées de manière irrégulière et souvent en réaction à un incident. Aucun test d'intrusion n'a été conduit depuis plusieurs années, ce qui laisse planer un doute sur la robustesse globale du dispositif. En l'état, WebMarket manipule donc des données de carte de manière risquée, au sein d'une architecture insuffisamment segmentée et protégée, et sans gouvernance structurée de la sécurité.

C'est dans ce contexte que vous êtes sollicités en tant que consultants en cybersécurité afin d'accompagner WebMarket dans une démarche de mise en conformité avec le standard PCI DSS. Votre mission débutera par une analyse approfondie de l'environnement existant, l'identification des zones sensibles et la compréhension des risques liés au traitement, à la transmission et au stockage des données de carte au sein de l'entreprise.

PARTIE 1 : Analyse et identification des enjeux PCI DSS

1. Identifiez les composants qui font partie du CDE (Cardholder Data Environment).

Incluez :

- systèmes stockant des données,
- systèmes traitant ou transmettant des données,
- systèmes connectés au CDE.

2. Quels sont les risques immédiats liés au stockage incorrect des données de carte ?

3. Quels sont les problèmes PCI DSS évidents dans la situation actuelle ?

PARTIE 2 : Proposer une architecture conforme PCI DSS

Votre objectif : définir une architecture sécurisée, accompagnée de mesures techniques pour réduire le périmètre PCI DSS et protéger les données.

4. Proposez une segmentation réseau conforme PCI DSS.

La segmentation doit couvrir les sous-réseaux suivants :

- un CDE isolé,
- un réseau utilisateur,
- un réseau administration,
- un DMZ web,
- des pare-feux.

PARTIE 3 : Proposer des mesures techniques alignées avec les 12 exigences PCI DSS

Proposer des mesures techniques concrètes pour chaque exigence, basée sur les objectifs et exigences PCI DSS.